



The Security Mandate: Structure, Strategy, and Stakes

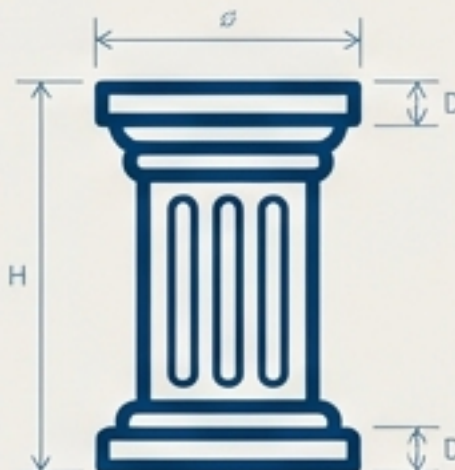
$$\overset{\beta}{\underset{r}{S}} = \overset{\theta}{\underset{\downarrow}{P}} + \overset{\theta}{\underset{\downarrow}{D}} + \overset{\theta}{\underset{\downarrow}{R}} \overset{\theta}{\underset{v}{}}$$

Security = Prevention + Detection + Response



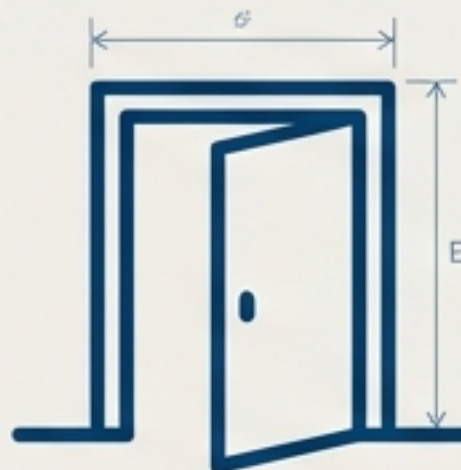
Confidentiality

Protecting data from unauthorized access.



Integrity

Ensuring data is not altered or tampered with.



Availability

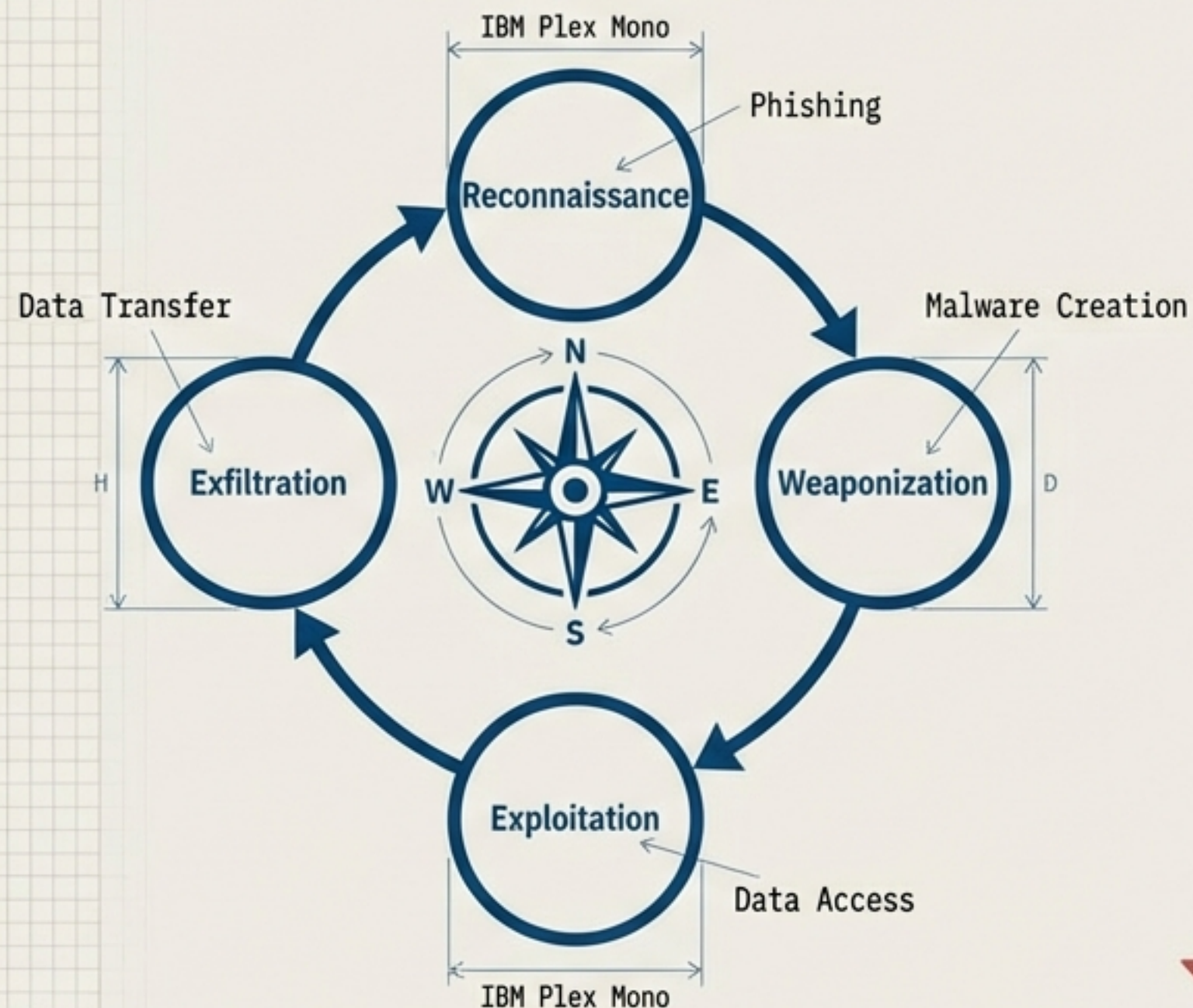
Ensuring systems are reliable and accessible.

- **Financial:** Average breach detection time is ~200 days. Costs are substantial.
- **Regulatory:** GDPR fines up to 4% global turnover. HIPAA fines \$1k-\$50k per violation.
- **Reputational:** Trust is hard to build and easy to lose.

PROJECT: SECURITY ARCHITECTURE		
DRAWN BY: AI	DATE: OCT 26, 2024	SHEET NO: 01 OF 01

The Threat Landscape: Knowing the Enemy

The Attack Lifecycle



Intelligence Disciplines

Threat Intelligence Types

- **Behavioral:** Analyzing attacker patterns and **TTPs** (Tactics, Techniques, Procedures). IBM Plex Mono
- **Reputational:** Tracking malicious **IPs, domains, and URLs**. IPs, domains, URLs

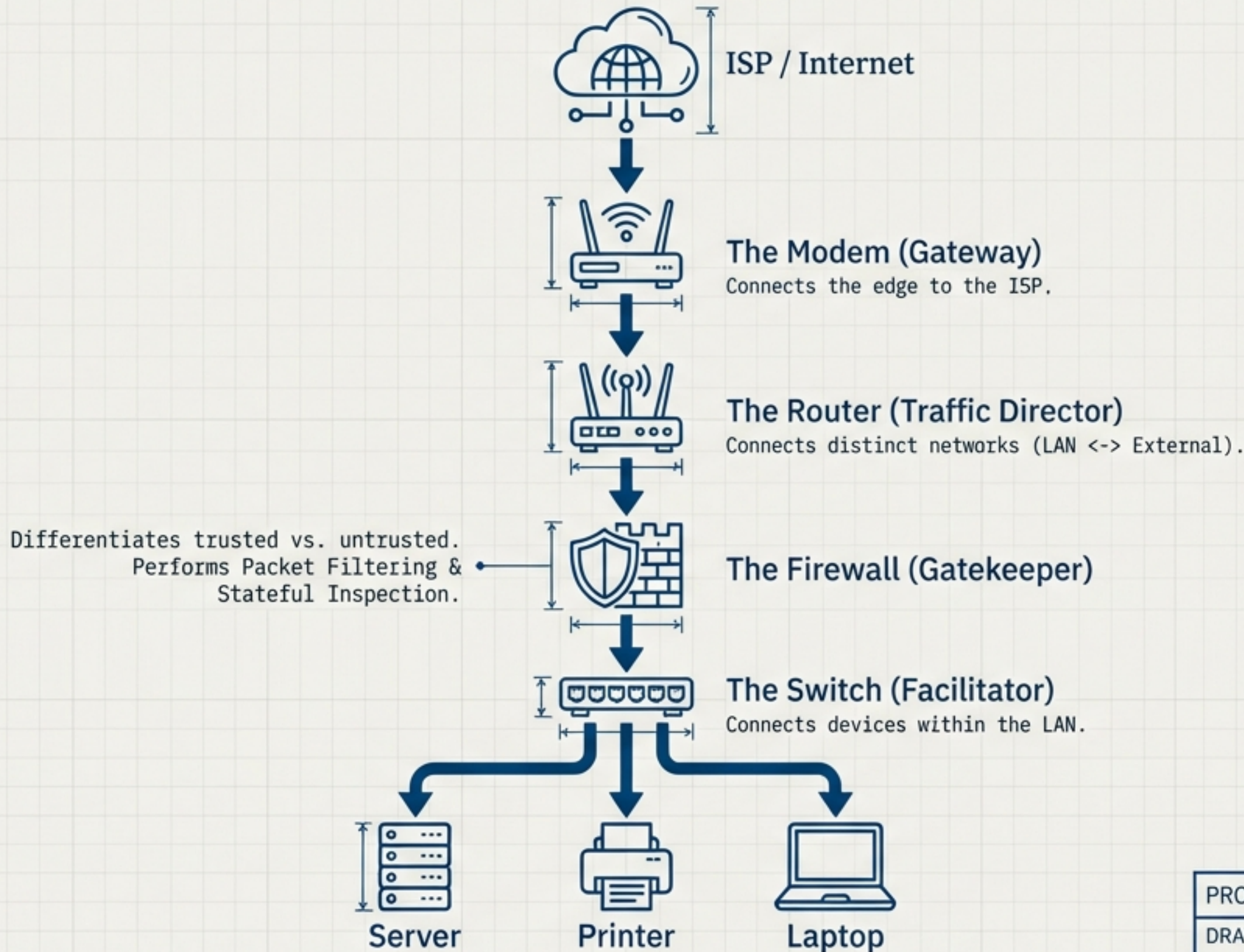
Intelligence Sources

- **Open Source:** Social media, forums, blogs.
- **Deep/Dark Web:** Unindexed sites, **Tor networks**, illicit marketplaces. Tor networks
- **Proprietary:** Paid feeds (e.g., **IBM X-Force Exchange**). IBM X-Force Exchange.

Key Insight: You cannot stop what you do not understand. Threat hunting is the proactive pursuit of the unseen.

PROJECT: SECURITY ARCHITECTURE		
DRAWN BY: AI	DATE: OCT 26, 2024	SHEET NO: 02 OF 02

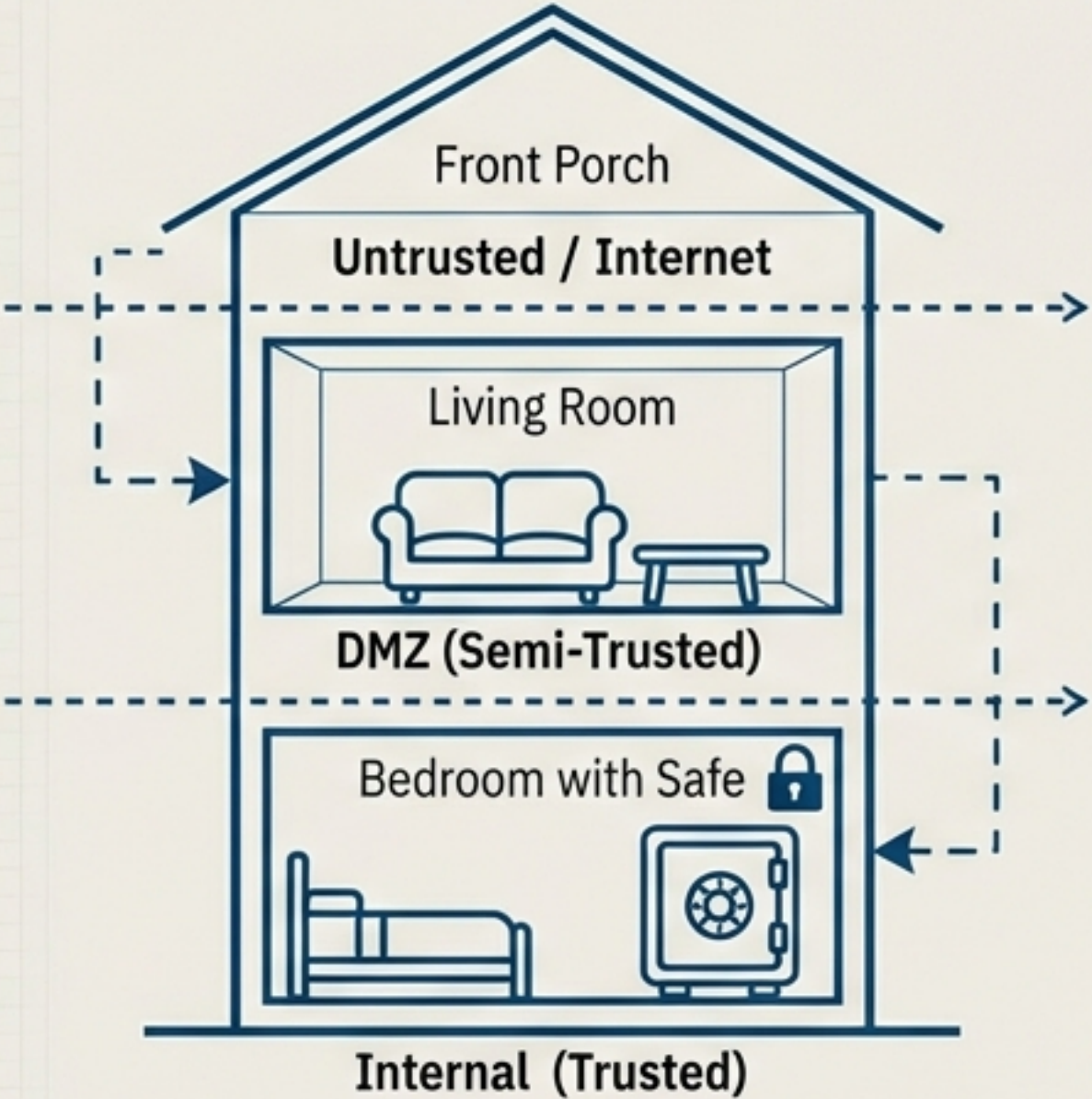
Network Architecture: The Anatomy of Trust



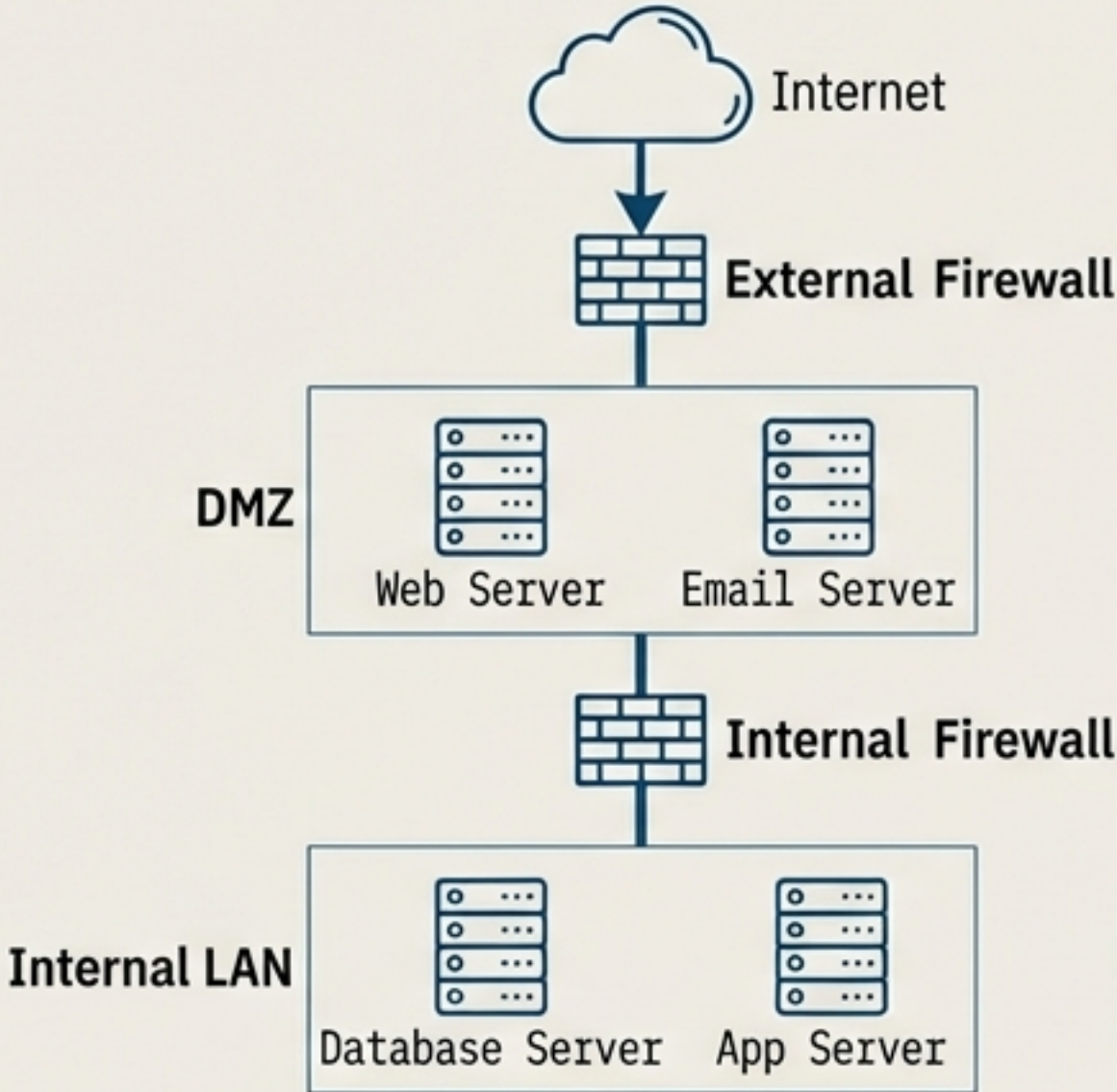
PROJECT: SECURITY ARCHITECTURE		
DRAWN BY: AI	DATE: OCT 26, 2024	SHEET NO: 03 OF 03

Designing the Secure Perimeter: The Zone Defense

The Metaphor (House)



The Technical Implementation



Defense in Depth: If the web server in the 'living room' is breached, the attacker still cannot open the safe in the 'bedroom'.

PROJECT: SECURITY ARCHITECTURE

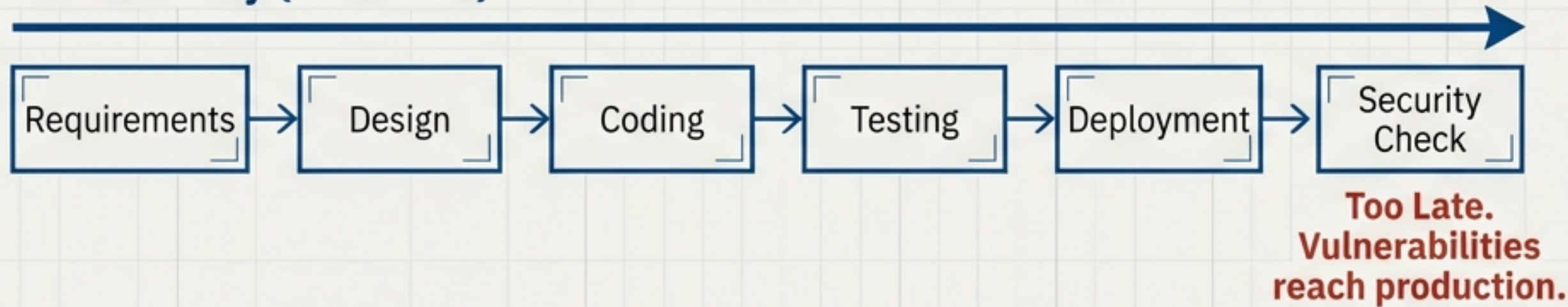
DRAWN BY:
AI

DATE:
OCT 26, 2024

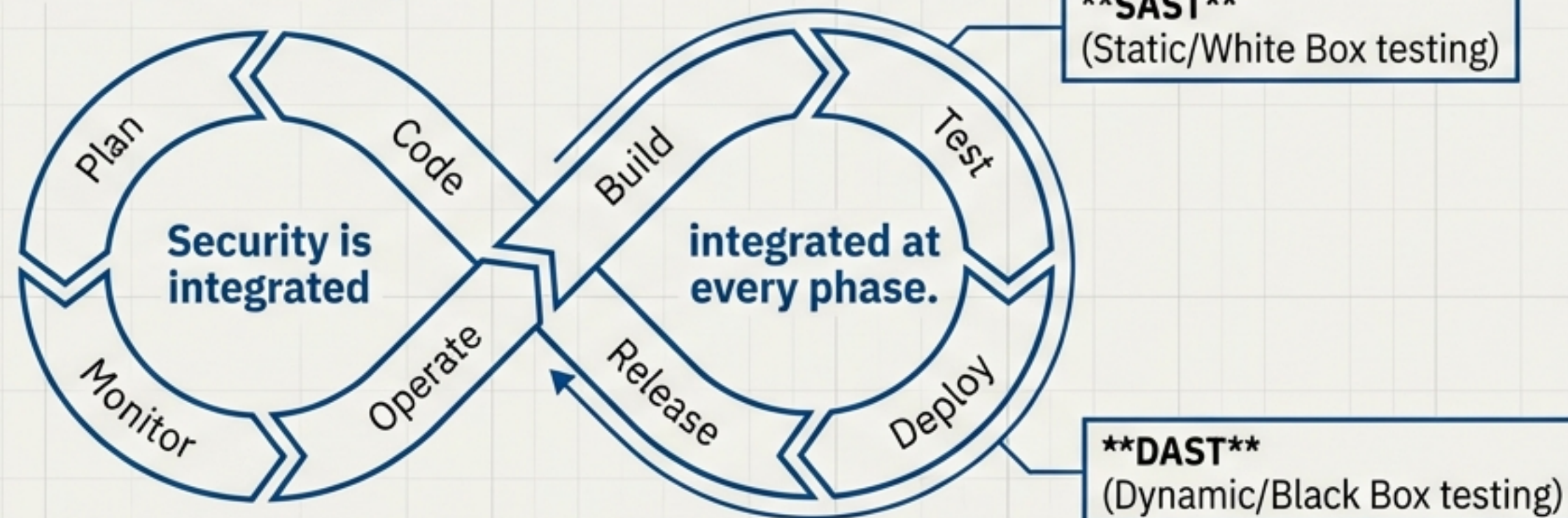
SHEET NO:
04 OF 04

Application Security: Shifting Left

The Old Way (Waterfall)



The New Way (DevSecOps)



Supply Chain Security

SBOM (Software Bill of Materials): A nested inventory of all ingredients (libraries, dependencies). Critical for identifying vulnerabilities in trusted components like Log4j.

PROJECT: SECURITY ARCHITECTURE

DRAWN BY: AI

DATE: OCT 26, 2024

SHEET NO:

05 OF 05

Hardening the Code: Defeating Common Vulnerabilities

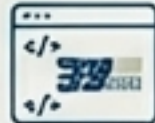
Addressing specific OWASP Risks found in the Jackson Corp Scenario



The Shield (Input Validation)

Risk:

Injection attacks (SQLi, XSS).



Fix:

```
^[s-2A-Z0-9._$!-]*@([3-2A-Z0-9.-]+\.([3-2A-Z]{2,})$
```

Validate all user data against expected formats (e.g., regex for emails). Never trust user input.



The Gate (Authentication)

Risk:

Weak passwords allow brute force attacks.



Fix:

Enforce complexity (12+ chars, mixed types), Implement MFA, and use hashing (never store plain text).



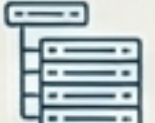
SHA-256



The Veil (Error Handling)

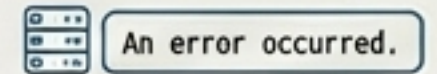
Risk:

Information leakage via stack traces.



Fix:

Display generic user messages. Log details internally but never display technical errors to the browser.



PROJECT: SECURITY ARCHITECTURE

DRAWN BY: AI

SHEET NO:

DATE: OCT 26, 2024

06 OF 06

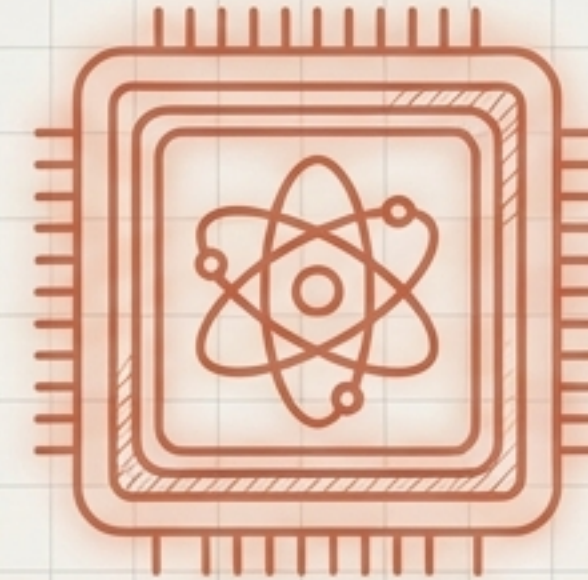
Data Seturity: Protecting the Crown Jewels

Current Defenses



- **At Rest:** Encrypted in storage.
- **In Transit:** Encrypted via TLS/SSL (HTTPS).
- **DLP (Data Loss Prevention):** Controls to block unauthorized exfiltration.
- **Key Management:** Keys managed separately from data.

The Future Threat



The Quantum Threat

- **Concept:** Harvest Now, Decrypt Later.
- **Description:** Attackers steal encrypted data today to crack it when quantum computers mature (Q-Day).
- **Solution:** Transition to Post-Quantum Cryptography (Lattice-based algorithms).

PROJECT: SECURITY ARCHITECTURE

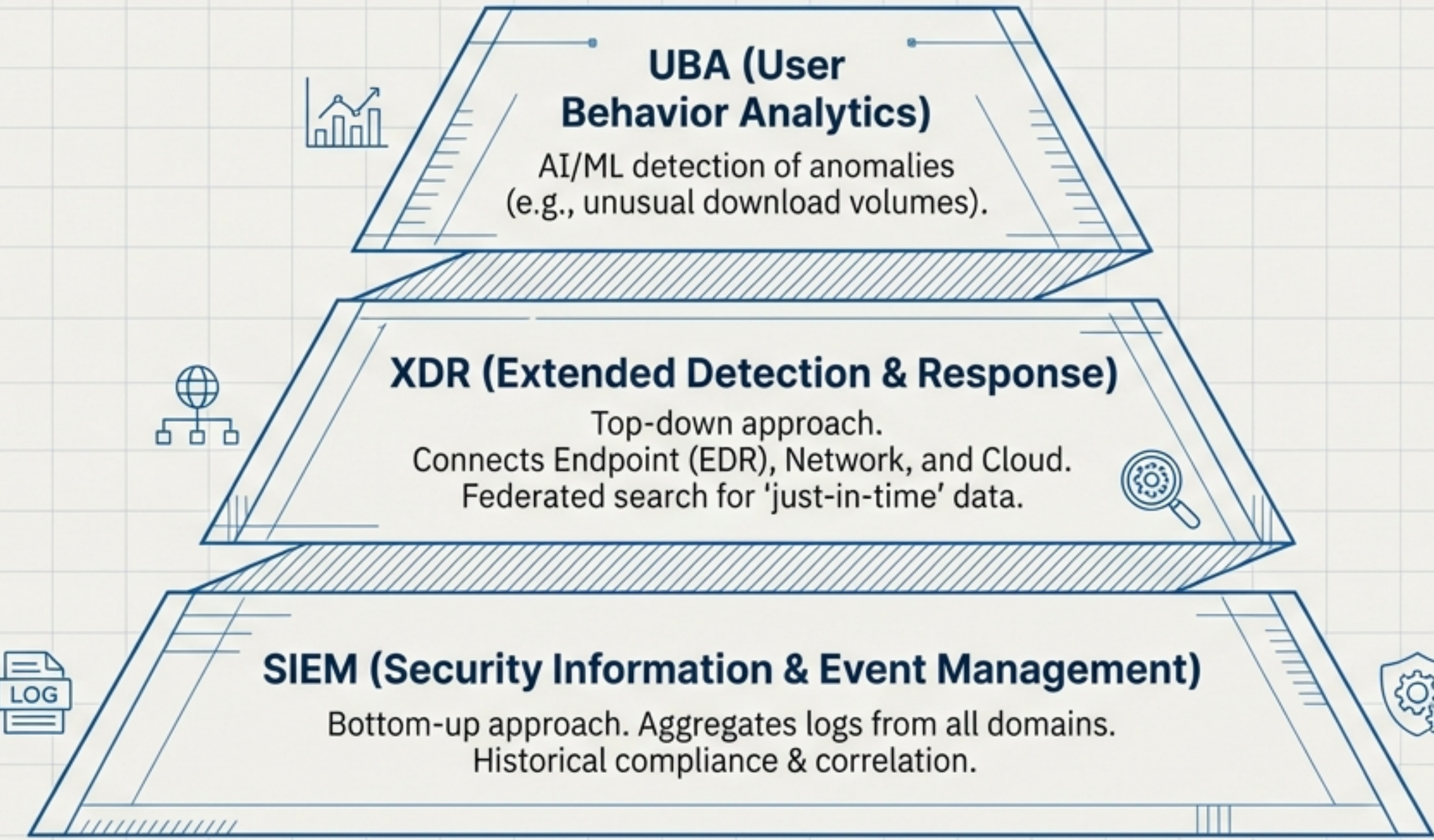
DRAWN BY: AI

SHEET NO: 07 OF 07

DATE: OCT 26, 2024

The Watchtower: Visibility and Detection

You cannot stop what you cannot see.



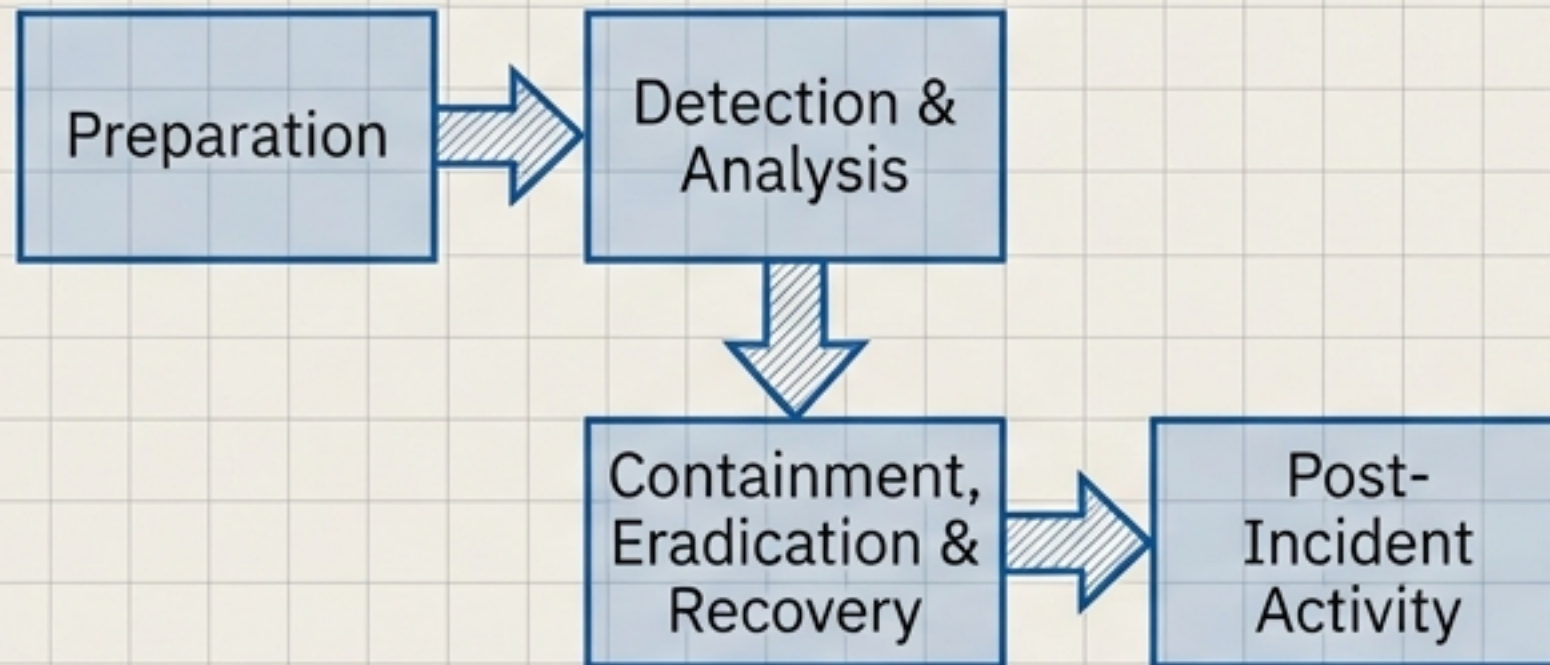
SOC (Security Operations Center)

The human team analyzing feeds to distinguish noise from threats.

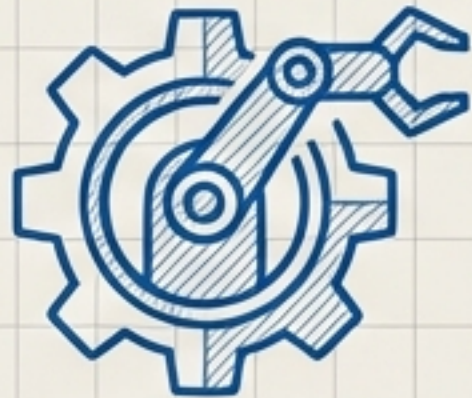
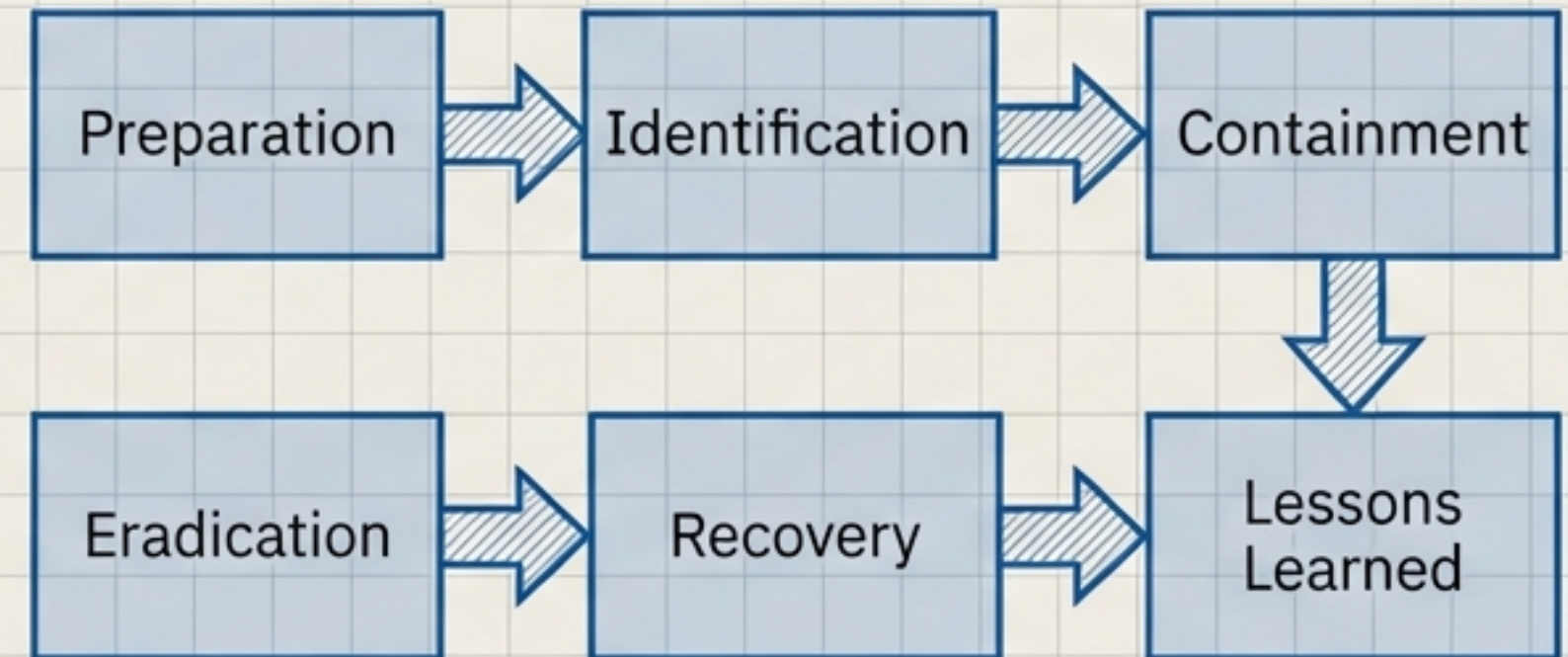
PROJECT: SECURITY ARCHITECTURE		
DRAWN BY:		
DATE: AI	DATE: OCT 26, 2024	SHEET NO: 08 OF 08

Incident Response: Turning Panic into Process

NIST Framework (4 Steps)



SANS Framework (6 Steps)



SOAR (Security Orchestration, Automation, and Response): Automating repetitive tasks to lower Mean Time to Contain (MTTC). Panic is not a strategy; dynamic playbooks ensure consistency.

PROJECT: SECURITY ARCHITECTURE

DRAWN BY:
AI

DATE:
OCT 26, 2024

SHEET NO:
09 OF 09

Real-World Evidence: Lessons from the Field

The Success

Case Study: The Co-operative Bank

Challenge: Migration from shared infrastructure.

Strategy: ‘Bubble’ testing and ‘Dress Rehearsals’ prior to cutover.

Outcome: Zero disruption. 250+ apps migrated with 100% success.



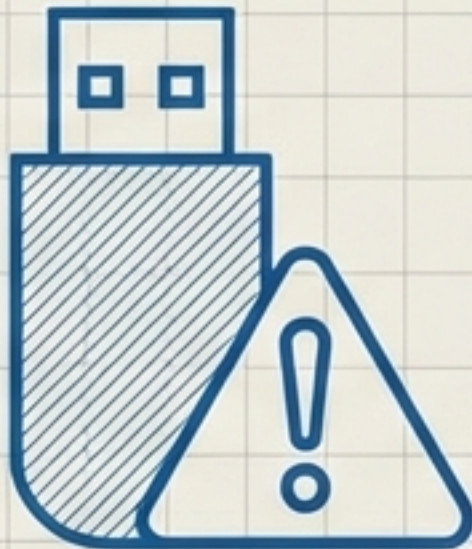
The Failure

Case Study: International Airport Breach

Scenario: Air-gapped network (physically isolated).

Failure: Malware introduced via USB; spread due to weak passwords.

Lesson: Isolation is not enough. Even air-gapped networks require Endpoint Detection (EDR) and strict physical media policies.



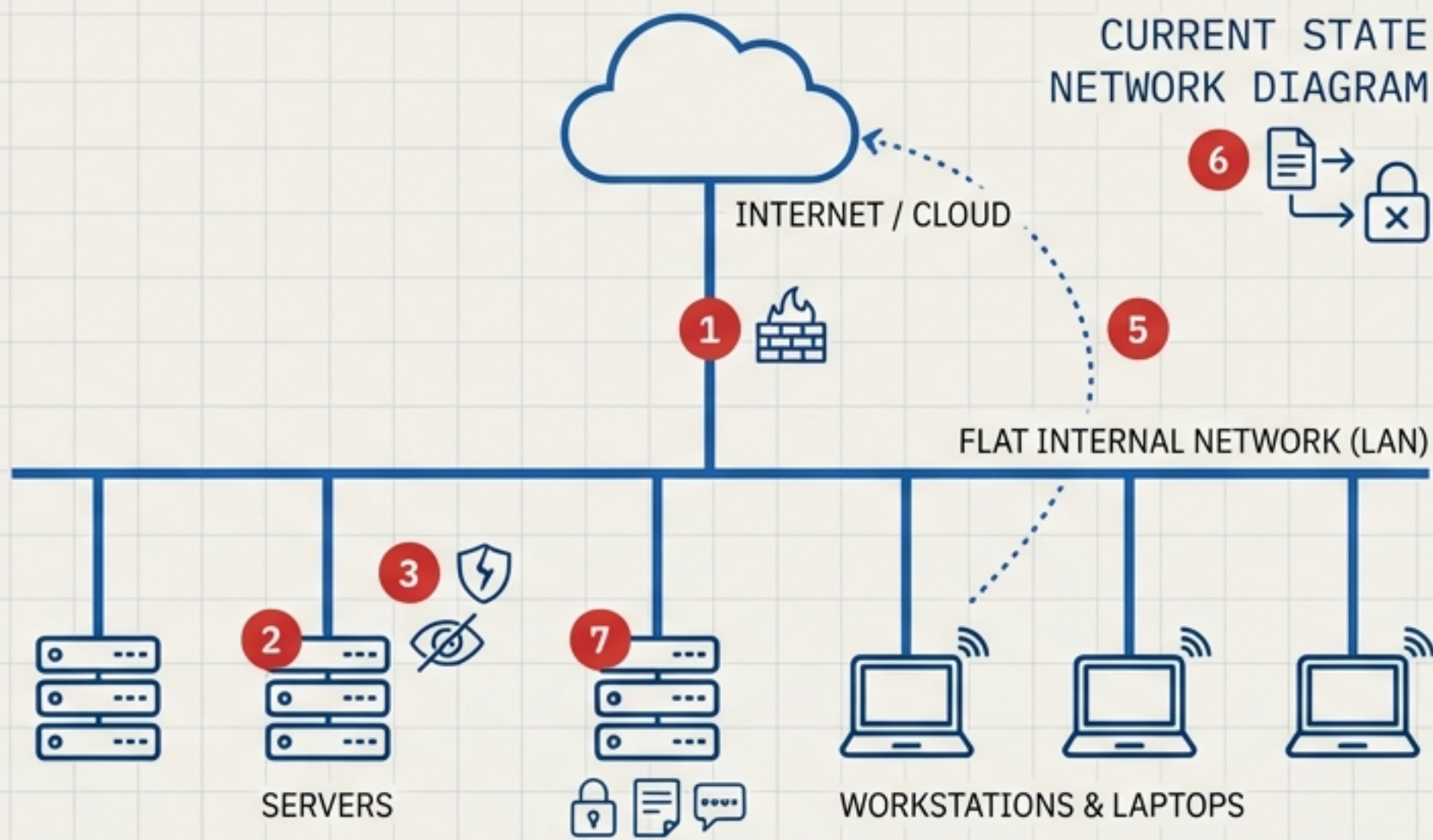
PROJECT: SECURITY ARCHITECTURE		
DRAWN BY: AI	DATE: OCT 26, 2024	SHEET NO: 10 OF 10

The Assessment: Jackson Corporation

Current State

CRITICAL GAPS

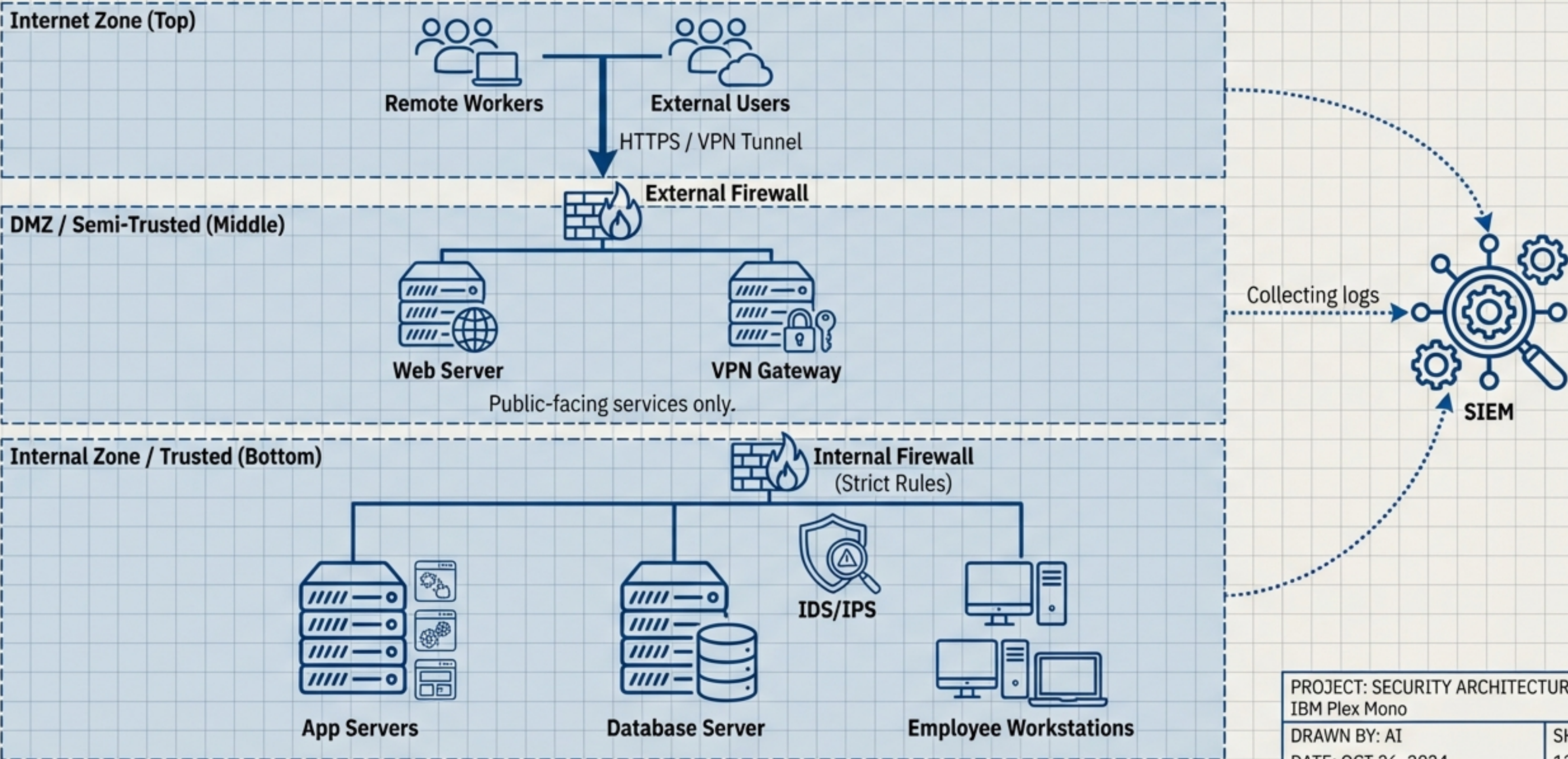
- 1 Firewall:** Single, flat firewall filtering indiscriminately.
- 2 Web Server:** Located internally (exposed to the LAN).
- 3 Monitoring:** No centralized system; reactive only.
- 4 Breach Detection:** Basic health checks only; no threat analysis.
- 5 Remote Work:** Accessing resources over public networks without VPN.
- 6 Development:** Waterfall method; no security in design.
- 7 App Security:** Weak passwords, plain text data, verbose errors, no input validation.



PROJECT:	
SECURITY ARCHITECTURE	DRAWN BY: AI
DATE: OCT 26, 2024	SHEET NO: 11 OF 11

The Blueprint: Secure Network Architecture

Proposed Segmentation for Jackson Corp



The Protocol: Policy and Process Enhancements

OWASP Issue A & B

Header: Access & Data

- **Passwords:** Enforce 12+ chars, complexity, and hashing.
- **Encryption:** Encrypt all sensitive DB fields (Credit Cards/SSN).

OWASP Issue C & D

Header: Code Hygiene

- **Input:** Implement server-side validation and sanitization.
- **Errors:** Disable verbose messages; use generic user alerts.

Workforce

Header: Remote Access

- Mandate **VPN** for all off-site connections.
- No direct access to internal resources from public Wi-Fi.

Development

Header: DevSecOps

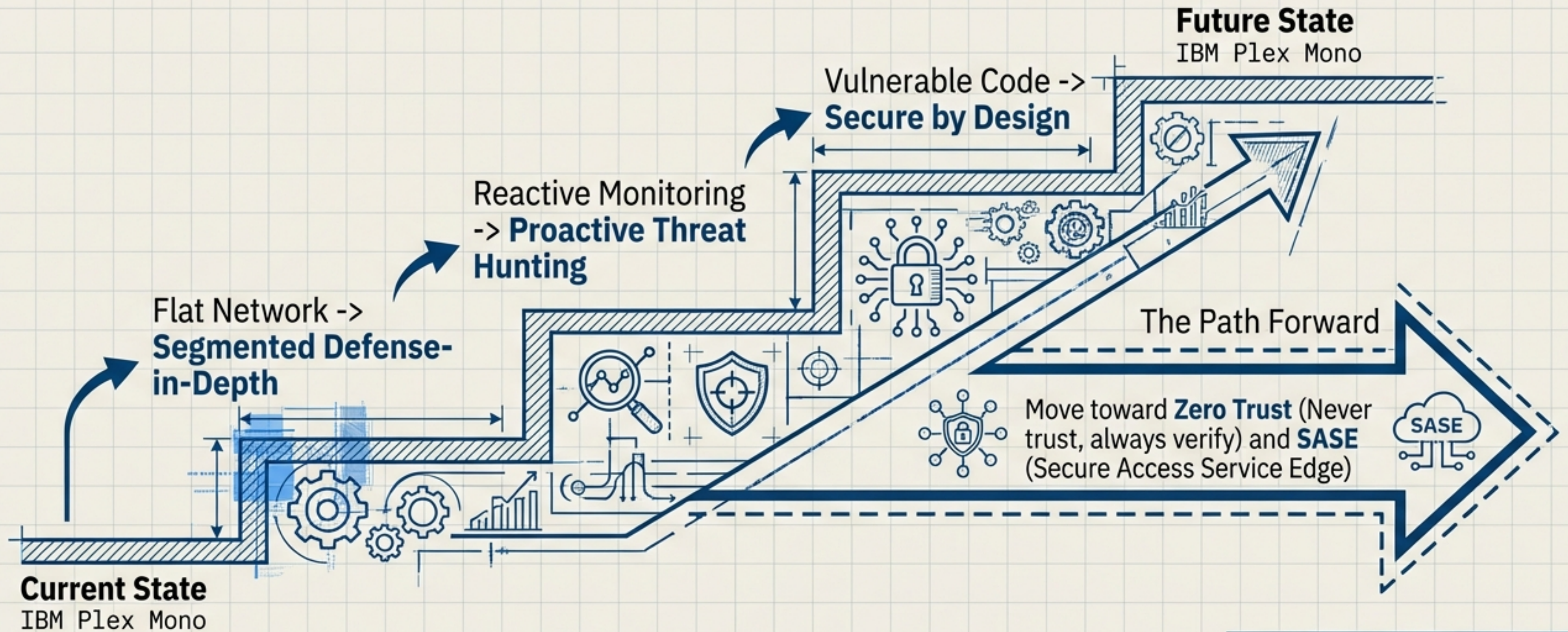
- Transition from Waterfall.
- Mandatory code reviews and automated testing pipelines.

PROJECT: SECURITY ARCHITECTURE
IBM Plex Mono

DRAWN BY: AI
DATE: OCT 26, 2024

SHEET NO:
13 OF 13

The Proactive Stance: Future-Proofing the Enterprise



Conclusion: Security is not a destination; it is a continuous journey of adaptation.

PROJECT: SECURITY ARCHITECTURE

IBM Plex Mono

DRAWN BY: AI

DATE: OCT 26, 2024

SHEET NO:

14 OF 14